

DFIR INVESTIGATION REPORT

Active Directory Domain Compromise — GhostTrace Incident

Classification: CONFIDENTIAL

Author: Mehenni May Fatma Zohra
Digital Forensics & Incident Response Analyst

Report Field	Detail
Incident Name	GhostTrace — Active Directory Domain Compromise
Environment	Main.local Active Directory Domain
Systems Affected	Client02 (192.168.204.129), Client03 (192.168.204.148), DC01 (192.168.204.10)
Attacker Infrastructure	192.168.204.152
Attack Vector	Phishing → Macro Execution → C2 → Kerberoasting → DCSync → Domain Compromise
Report Date	2025-12-02
Severity	CRITICAL
Status	Investigation Complete

1. Executive Summary

This report documents the forensic investigation of a sophisticated, multi-stage intrusion that resulted in the complete compromise of the Main.local Active Directory domain. The attack chain began with a targeted phishing campaign against an end-user on Client02 and progressed through credential theft, lateral movement, and ultimately full domain takeover — including extraction of the Domain Administrator's NTLM hash.

The investigation was conducted through analysis of Windows Event Logs, Sysmon telemetry, PowerShell transcripts, and Master File Table (\$MFT) artifacts collected from three systems: Client02, Client03, and the Domain Controller (DC01). By correlating events across these sources, the analyst was able to reconstruct the complete attack chain with high confidence.

 Critical Finding

The attacker achieved Domain Administrator-level access within approximately 3 hours and 30 minutes of initial phishing document execution, culminating in a DCSync attack, extraction of the NTLM hash of the Administrator account, and establishment of multiple persistence mechanisms on the Domain Controller.

Key Findings at a Glance

Phase	Key Artifact	Timestamp (UTC)
Initial Access	Profits.docm downloaded from 192.168.204.152	2025-05-25 01:27:50
C2 Established	WINWORD.EXE → 192.168.204.152:4444	2025-05-25 01:29:06
Second-Stage Payload	UpdatePolicy.exe uploaded; reverse shell on port 1337	2025-05-25 01:32:17
AD Enumeration	PowerView.ps1 downloaded and executed	2025-05-25 04:47:25
Kerberoasting	TGS ticket requested for sqlsvc account	2025-05-25 03:42:33
Lateral Movement	sqlsvc credentials used to access Client03	2025-05-25 04:03:47
Credential Dumping	netdiag.exe (Mimikatz) executed on Client03	2025-05-25 04:12:50
DCSync Attack	lucas account used to replicate domain secrets	2025-05-25 04:26:36
Domain Compromise	Administrator NTLM hash cracked; WinRM access to DC01	2025-05-25 04:34:01
Persistence	WindowsUpdateSvc service, WindowsUpdateCheck task, xcvafr registry key	2025-05-25 06:38–06:43

2. Environment Overview

The compromised environment is an Active Directory domain named Main.local. Three systems were analyzed during this investigation, each contributing distinct forensic artifacts.

Hostname	IP Address	Role	Primary Users
Client02	192.168.204.129	Domain-joined workstation — Initial compromise point	jody (MAIN\jody)
Client03	192.168.204.148	Domain-joined workstation — Lateral movement target	lucas (MAIN\lucas)
DC01	192.168.204.10	Domain Controller — Final target (domain compromise)	Administrator (MAIN\Administrator)
Attacker Host	192.168.204.152	External attacker-controlled infrastructure	N/A

Artifact Sources

The following forensic artifacts were collected and analyzed during this investigation:

- Windows Security Event Logs (.evtx) — from all three systems
- Sysmon Operational Logs (.evtx) — from all three systems
- PowerShell Module/Pipeline Logs (.evtx) — from Client02 and Client03
- Master File Table (\$MFT) — from Client02 and Client03 C: volumes

Why These Artifact Sources?

Each artifact source serves a distinct investigative purpose. Windows Security logs capture authentication events, privilege usage, and service creation. Sysmon provides granular process, network, and file activity telemetry that the native Security log does not. PowerShell logs reveal attacker scripts and commands. The \$MFT provides an authoritative record of file creation, modification, and deletion — including files that may have been subsequently removed by the attacker.

```
PS C:\Users\May\Desktop\GhostTrace> tree
Folder PATH listing
Volume serial number is C20A-1DF4
C:.
|_ Logs-Client02
|   |_ C
|_ Logs-Client03
|   |_ C
|_ Logs-DC
|   |_ C
```

Figure: Directory tree of collected forensic artifacts showing logs from Client02, Client03, and DC01

3. Investigation Methodology

The investigation followed a structured Digital Forensics and Incident Response (DFIR) framework based on the SANS PICERL model (Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned). The analysis phase focused primarily on Identification — reconstructing the complete attack chain from initial access to domain compromise.

Analytical Approach

Rather than examining each log source in isolation, the analyst employed a cross-artifact correlation methodology: findings from one artifact source were used to form hypotheses that were subsequently validated or refuted by examining a second source. This approach dramatically reduces the risk of missing attacker activity that might be visible in only one log type.

Phase	Primary Tool / Log Source	Key Event IDs
Initial Access	Sysmon (Client02)	Event ID 11 (FileCreate), Event ID 15 (FileStream)
C2 Activity	Sysmon (Client02)	Event ID 3 (NetworkConnect)
AD Enumeration	PowerShell Logs (Client02)	Event ID 4103 (Module Logging)
Kerberoasting	Security Logs (DC01)	Event ID 4769 (TGS Ticket Request)
Lateral Movement	Security Logs (Client03)	Event ID 4624 (Logon)
Credential Dumping	Sysmon (Client03)	Event ID 1 (ProcessCreate)
DCSync	Security Logs (DC01)	Event ID 4662 (Directory Object Access)
Domain Compromise	Sysmon / Security (DC01)	Event ID 3, 4624
Persistence	Security / Sysmon (DC01)	Event ID 4698, 4688, Sysmon ID 13

Event ID Reference Guide

For readers unfamiliar with Windows event logging, the following table explains every Event ID referenced in this report and why it is forensically significant:

Event ID	Source	Description	Investigative Value
1	Sysmon	Process Creation	Records every process launch with full command line, hashes, and parent process — critical for detecting renamed malware and attacker tooling

Event ID	Source	Description	Investigative Value
3	Sysmon	Network Connection	Logs outbound TCP/UDP connections per-process — essential for identifying C2 channels and lateral movement traffic
11	Sysmon	File Created	Records file creation events — used to identify phishing attachments landing on disk
13	Sysmon	Registry Value Set	Records registry modifications — used to detect persistence via Run keys
15	Sysmon	File Stream Created	Triggered when an Alternate Data Stream is created on a file — a reliable indicator that a file was downloaded from the internet
4103	PowerShell	Module/Pipeline Logging	Records PowerShell script execution and pipeline content — reveals attacker scripts run in memory
4624	Security	Successful Logon	Records every successful authentication — critical for tracing attacker lateral movement
4662	Security	Object Operation Performed	Records operations on AD objects — key for detecting DCSync (replication permission abuse)
4688	Security	Process Created	Windows native process creation log — supplements Sysmon for service and sc.exe activity
4698	Security	Scheduled Task Created	Records new scheduled task creation — persistence detection
4769	Security	Kerberos Service Ticket Requested	Logs every TGS ticket request — essential for Kerberoasting detection

4. Initial Access Analysis

Attacker Objective

The attacker's goal in this phase was to gain a foothold on a user's workstation within the target domain. The chosen method was spear-phishing — delivering a malicious document capable of executing attacker-controlled code upon opening.

Analyst Hypothesis

When investigating a suspected breach, the analyst's first question is: how did the attacker get in? In an Active Directory environment, phishing is statistically the most common initial access vector. The investigation therefore began by examining Client02's file system telemetry for evidence of a suspicious document download.

Log Source Selection Rationale

Sysmon Event ID 11 (FileCreate) was selected as the primary starting artifact because it records every file written to disk, including metadata about the creating process. Crucially, Sysmon Event ID 15 (FileStream Create) records the creation of NTFS Alternate Data Streams (ADS) — specifically the :Zone.Identifier stream that Windows automatically appends to any file downloaded from the internet. This ADS stream is one of the most reliable indicators of a file's external origin and is far more difficult for an attacker to remove without leaving additional traces.

The analyst began by filtering Sysmon logs for Event ID 11 on Client02, limiting results to file extensions commonly used in phishing attacks: .vbs, .rtf, .lnk, .bat, .ps1, .docm, .docx, and .pdf. This targeted approach avoids the noise of thousands of legitimate file creation events and focuses attention on high-risk file types.

```

PS C:\Users\May\Desktop\GhostTrace\Logs-Client02> Get-WinEvent -Path .\Sysmon.evtx |
>> Where-Object {
>>     $_.Id -eq 11 -and
>>     $_.Properties[5].Value -match '\.vbs$|\.rtf|\.LNK|\.bat|\.ps1|\.docm|\.docx?|\.pdf'
>> } |
>> Select-Object TimeCreated,
>>     @(Name='TargetFileName'; Expression={$_.Properties[5].Value}),
>>     @(Name='User'; Expression={$_.Properties[7].Value})

```

TimeCreated	TargetFileName
5/25/2025 5:50:31 AM	C:\Users\administrator\AppData\Local\Temp__PSScriptPolicyTest_...
5/25/2025 4:39:22 AM	C:\Users\jody\AppData\Local\Temp__PSScriptPolicyTest_53w4qzcz...
5/25/2025 4:37:05 AM	C:\Users\jody\Downloads\PowerView.ps1
5/25/2025 4:37:03 AM	C:\Users\jody\AppData\Local\Temp__PSScriptPolicyTest_0sjbuygn...
5/25/2025 4:31:47 AM	C:\Users\jody\AppData\Local\Temp__PSScriptPolicyTest_hfit5vyk...
5/25/2025 4:28:34 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:28:34 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:28:05 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:28:05 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:28:04 AM	C:\Users\jody\AppData\Local\Packages\oice_16_974fa576_32c1d314_...
5/25/2025 4:28:03 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:28:03 AM	C:\Users\jody\AppData\Roaming\Microsoft\Office\Recent\Profits.LNK
5/25/2025 4:27:50 AM	C:\Users\jody\Downloads\Profits.docm:Zone.Identifier
5/25/2025 4:27:09 AM	C:\Users\jody\AppData\Local\Temp__PSScriptPolicyTest_55gcqdpk...
5/25/2025 4:26:58 AM	C:\\$Recycle.Bin\S-1-5-21-620716483-2719109048-3577772375-2107\...
5/25/2025 4:24:08 AM	C:\\$Recycle.Bin\S-1-5-21-620716483-2719109048-3577772375-2107\...
5/25/2025 4:24:05 AM	C:\\$Recycle.Bin\S-1-5-21-620716483-2719109048-3577772375-2107\...

Figure: Sysmon Event ID 11 filter results showing Profits.docm downloaded to C:\Users\jody\Downloads

The results immediately revealed a Microsoft Word macro-enabled document (Profits.docm) in the Downloads folder of user jody. Three corroborating artifacts were observed:

1. The file Profits.docm appeared in C:\Users\jody\Downloads\
2. A corresponding Profits.LNK shortcut was created — indicating the user opened the document
3. A :Zone.Identifier ADS was recorded (Profits.docm:Zone.Identifier) — confirming internet origin

Analyst Note — Why .docm?

The .docm extension denotes a Microsoft Word document with embedded macros. This format is a classic phishing vehicle because macros execute VBA code with the privileges of the logged-in user the moment the document is opened and macros are enabled. Unlike executables, .docm files often bypass gateway filtering and appear legitimate to end users.

In Use	Parent Path	File Name	Extension	Is Directory	Has Ads	Is Ads	File Size
☒	.\Users\jody\Downloads	delete		☐	☐	☐	1
☒	.\Users\jody\Downloads	Profits.docm	.docm	☐	☒	☐	1447
☒	.\Users\jody\Downloads	Profits.docm:Zone.Identifier	.Identifier	☐	☐	☒	7
☒	.\Users\jody\Downloads\sysmon	Eula.txt	.txt	☐	☐	☐	749
☒	.\Users\jody\Downloads\sysmon	script.ps1	.ps1	☐	☐	☐	117
☒	.\Users\jody\Downloads\sysmon	stop		☐	☐	☐	1
☒	.\Users\jody\Downloads\sysmon	Sysmon.exe	.exe	☐	☐	☐	848056
☒	.\Users\jody\Downloads\sysmon	Sysmon64.exe	.exe	☐	☐	☐	456324
☒	.\Users\jody\Downloads\sysmon	Sysmon64a.exe	.exe	☐	☐	☐	499344
☒	.\Users\jody\Downloads\sysmon	sysmonconfig.xml	.xml	☐	☐	☐	25316
☒	.\Users\jody\Downloads	UpdatePolicy.exe	.exe	☐	☐	☐	716
☒	.\Users\jody\Downloads	PowerView.ps1	.ps1	☐	☐	☐	77027

Figure: \$MFT analysis in Timeline Explorer confirming Profits.docm and its Zone.Identifier ADS in the Downloads folder

The \$MFT analysis in Timeline Explorer served as a second independent confirmation of the same finding — critically important in forensics where corroboration between artifact sources validates the finding. The presence of both the document and its Zone.Identifier stream in the \$MFT confirms the file was downloaded rather than copied locally.

To identify the download source, the analyst pivoted to Sysmon Event ID 15, which includes the HostURL field from the Zone.Identifier content. This revealed that Profits.docm was downloaded directly from <http://192.168.204.152/Profits.docm> — the attacker's command-and-control server.

```
PS C:\Users\May\Desktop\GhostTrace\Logs-Client02> Get-WinEvent -Path .\Sysmon.evtx |
>> Where-Object { $_.Id -eq 3 -and $_.Properties[14].Value -eq '192.168.204.152' } |
>> Select-Object TimeCreated,
>> @{Name='Image'; Expression={$_.Properties[4].Value}},
>> @{Name='DestIP'; Expression={$_.Properties[14].Value}},
>> @{Name='DestPort'; Expression={$_.Properties[16].Value}}
```

TimeCreated	Image	DestIP	DestPort
5/25/2025 5:28:20 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:37:07 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:26 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:32:17 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:04 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:29:06 AM	C:\Program Files\Microsoft Office\root\Office16\WINWOR...	192.168.204.152	4444

Figure: Sysmon Event ID 15 showing Zone.Identifier content with HostUrl=<http://192.168.204.152/Profits.docm>

✓ Conclusion — Initial Access

User jody on Client02 downloaded a macro-enabled Word document named Profits.docm from attacker-controlled infrastructure at 192.168.204.152. The file was opened shortly after download, as evidenced by the creation of the Profits.LNK shortcut. This constitutes the initial access event.

5. Command and Control Activity

Attacker Objective

Following macro execution, the attacker's goal was to establish a persistent, interactive command channel back to their infrastructure — enabling remote control of the compromised workstation without requiring repeated phishing.

Analyst Hypothesis

Malicious Word macros most commonly achieve code execution by launching a subprocess (such as cmd.exe or PowerShell) or initiating a network callback. Because WINWORD.EXE is the process that executes the macro, examining outbound network connections initiated by that process is the most direct method to identify C2 activity. Sysmon Event ID 3 (Network Connection) was therefore selected as the primary analytical lens.

The analyst filtered Sysmon Event ID 3 records where the initiating process contained winword.exe. This targeted approach avoids the false positives generated by legitimate Microsoft Office telemetry (which connects to Microsoft's cloud services) by focusing specifically on connections to non-Microsoft destinations.

```
PS C:\Users\May\Desktop\GhostTrace\Logs-Client02> Get-WinEvent -Path .\Sysmon.evtx |
>> Where-Object { $_.Id -eq 3 -and $_.Properties[4].Value -like '*winword.exe*' } |
>> Select-Object TimeCreated,
>> @{Name='Image'; Expression={$_.Properties[4].Value}},
>> @{Name='DestIP'; Expression={$_.Properties[14].Value}},
>> @{Name='DestPort'; Expression={$_.Properties[16].Value}}

TimeCreated      Image                                     DestIP      DestPort
-----
5/25/2025 4:29:06 AM C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE 192.168.204.152 4444
```

Figure: Sysmon Event ID 3 showing WINWORD.EXE initiating a connection to 192.168.204.152:4444

The results revealed a single outbound connection from C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE to 192.168.204.152:4444. Port 4444 is the default listener port for Metasploit Framework's Meterpreter — one of the most widely used penetration testing and offensive frameworks. This is a strong indicator of an automated reverse shell payload embedded in the macro.

Analyst Note — Why Port 4444?

Port 4444 is the default Metasploit Meterpreter reverse TCP listener port. While sophisticated attackers often change this to blend with legitimate traffic (e.g., port 443/HTTPS), many commodity attacks and script-based intrusions retain the default. Its appearance here, combined with the WINWORD.EXE initiator, constitutes a high-confidence C2 indicator.

Second-Stage Payload

With the initial Meterpreter session established, the attacker proceeded to upload a second-stage payload to the victim machine. To identify this, the analyst expanded the Sysmon Event ID 3 query to capture all processes communicating with the attacker's IP (192.168.204.152), not limited to WINWORD.EXE. This revealed additional processes making connections to the same infrastructure on port 1337.

```
PS C:\Users\May\Desktop\GhostTrace\Logs-Client02> Get-WinEvent -Path .\Sysmon.evtx |
>> Where-Object { $_.Id -eq 3 -and $_.Properties[14].Value -eq '192.168.204.152' } |
>> Select-Object TimeCreated,
>>     @{Name='Image'; Expression={$_.Properties[4].Value}},
>>     @{Name='DestIP'; Expression={$_.Properties[14].Value}},
>>     @{Name='DestPort'; Expression={$_.Properties[16].Value}}
```

TimeCreated	Image	DestIP	DestPort
5/25/2025 5:28:20 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:37:07 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:26 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:32:17 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:04 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:29:06 AM	C:\Program Files\Microsoft Office\root\Office16\WINWOR...	192.168.204.152	4444

Figure: Sysmon Event ID 3 showing UpdatePolicy.exe connecting to 192.168.204.152:1337

A second executable, UpdatePolicy.exe, was observed initiating connections to 192.168.204.152:1337. The name UpdatePolicy.exe is a deliberate masquerade — designed to appear as a legitimate Windows policy update process to casual observation. Port 1337 (a number colloquially used in hacker culture) served as the second reverse shell port, confirming this was an attacker-uploaded payload providing a more stable, persistent command channel.

```
PS C:\Users\May\Desktop\GhostTrace\Logs-Client02> Get-WinEvent -Path .\Sysmon.evtx |
>> Where-Object { $_.Id -eq 3 -and $_.Properties[14].Value -eq '192.168.204.152' } |
>> Select-Object TimeCreated,
>>     @{Name='Image'; Expression={$_.Properties[4].Value}},
>>     @{Name='DestIP'; Expression={$_.Properties[14].Value}},
>>     @{Name='DestPort'; Expression={$_.Properties[16].Value}}
```

TimeCreated	Image	DestIP	DestPort
5/25/2025 5:28:20 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:37:07 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:26 AM	C:\Users\jody\Downloads\UpdatePolicy.exe	192.168.204.152	1337
5/25/2025 4:32:17 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:32:04 AM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	192.168.204.152	80
5/25/2025 4:29:06 AM	C:\Program Files\Microsoft Office\root\Office16\WINWOR...	192.168.204.152	4444

Figure: Sysmon Event ID 3 full results showing both UpdatePolicy.exe (port 1337) and PowerShell (port 80) connecting to attacker infrastructure

Notably, PowerShell connections to port 80 on the same attacker IP were also observed — indicating the attacker was using PowerShell for additional download or execution activity over HTTP, consistent with subsequent tool staging.

✓ Conclusion — C2 Activity

The attacker established two distinct command-and-control channels: an initial Meterpreter session via WINWORD.EXE on port 4444, followed by a second-stage reverse shell via UpdatePolicy.exe on port 1337. Both channels communicated with attacker infrastructure at 192.168.204.152.

6. Active Directory Enumeration

Attacker Objective

Before launching credential attacks, the attacker needed to map the Active Directory environment — identifying users, groups, service accounts, trust relationships, and potential privilege escalation paths. This intelligence-gathering phase is essential for targeted attacks.

Analyst Hypothesis

Attackers typically use well-known PowerShell-based AD enumeration tools delivered through the established C2 channel. PowerShell Module Logging (Event ID 4103) captures the pipeline execution of PowerShell commands, including script names and parameter bindings — making it the ideal source for identifying attacker tooling. The analyst examined Client02's PowerShell logs, filtering for Event ID 4103 and looking for known AD enumeration tool signatures such as BloodHound, PowerView, ADRecon, and similar frameworks.

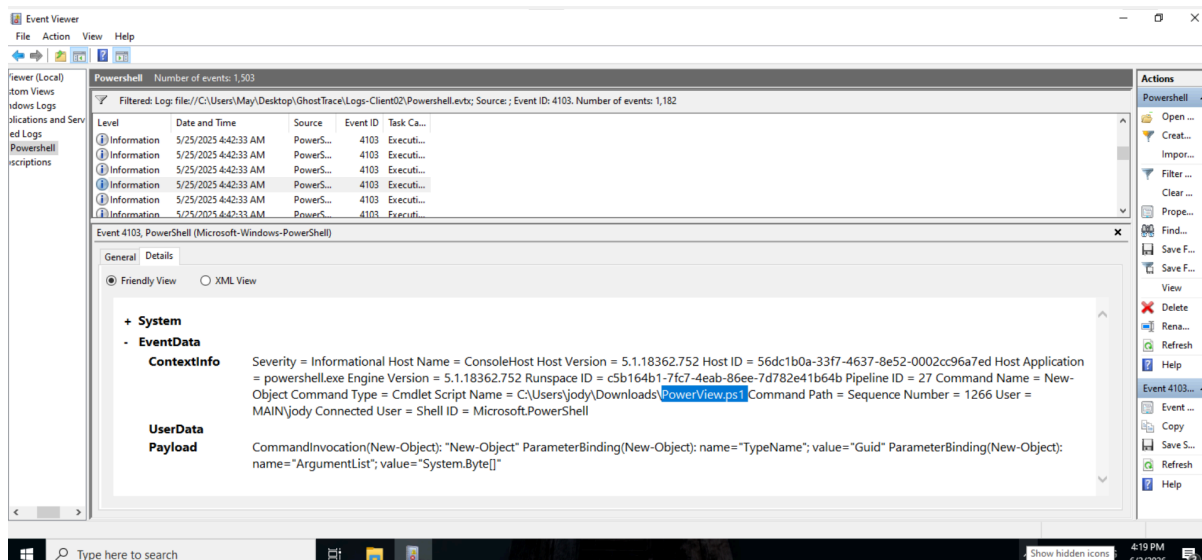


Figure: PowerShell Event ID 4103 showing PowerView.ps1 executing — Command Name field confirms the script path C:\Users\jody\Downloads\PowerView.ps1

The PowerShell pipeline logs clearly showed PowerView.ps1 executing from C:\Users\jody\Downloads\. The Command Name field in Event ID 4103 explicitly contained the script path, and the pipeline parameters showed enumeration cmdlets being called. PowerView is a component of the PowerSploit framework — a widely-used offensive PowerShell toolkit originally developed for red team operations.

Analyst Note — PowerView Capabilities

PowerView provides comprehensive Active Directory enumeration capabilities including: Get-DomainUser (enumerate all domain users), Get-DomainComputer (enumerate domain

computers), Get-DomainGroup (enumerate group memberships), and critically — Get-DomainSPNTicket (request Kerberos service tickets for Kerberoasting attacks). Its presence immediately raised the hypothesis that a Kerberoasting attack had occurred.

7. Kerberoasting Activity

Attacker Objective

Kerberoasting is an Active Directory attack technique that exploits the Kerberos authentication protocol. Any authenticated domain user can request a Ticket Granting Service (TGS) ticket for any service registered with a Service Principal Name (SPN). These tickets are encrypted with the service account's password hash — allowing an attacker to extract the ticket and crack the password offline, away from any detection mechanisms.

Why Kerberoasting is Particularly Dangerous

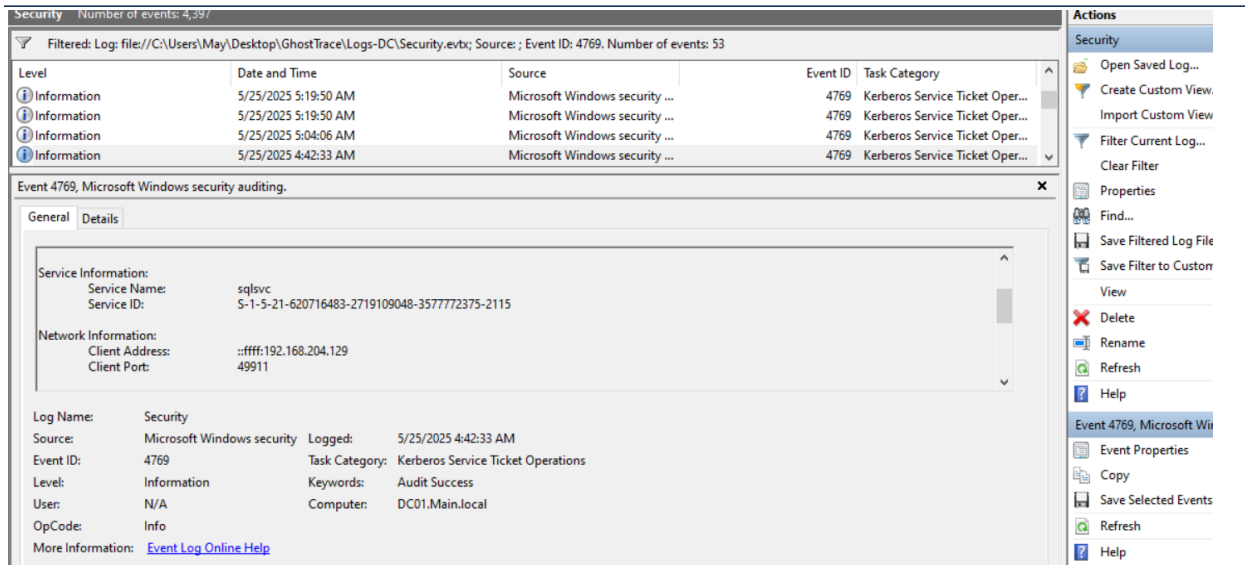
Because TGS requests are a normal part of Kerberos operations, Kerberoasting blends into legitimate traffic and often evades network-level detection. The attack requires only a valid domain account — no special privileges. Service accounts frequently have weaker passwords (because they are not subject to regular password changes) and often have elevated privileges, making them high-value targets.

Analyst Hypothesis & Log Selection

The discovery of PowerView.ps1 — which includes the Get-DomainSPNTicket cmdlet — immediately prompted the analyst to investigate whether a Kerberoasting attack had been executed. Kerberoasting activity is recorded on the Domain Controller in the Security log as Event ID 4769 (A Kerberos service ticket was requested).

Critically, the analyst pivoted from Client02 logs to the Domain Controller's Security log — because TGS ticket requests are processed by the DC's Kerberos Distribution Center (KDC), not the client workstation. This is an important investigative insight: the evidence for authentication attacks often exists on the authenticating server rather than the attacking client.

The analyst filtered DC01's Security log for Event ID 4769, excluding computer account requests (which contain a trailing dollar sign and represent normal machine authentication). The results revealed a TGS ticket requested by the compromised jody account for the service account sqlsvc.



The Event ID 4769 record provided critical evidence: the Account Name (jody@MAIN.LOCAL), the Service Name (sqlsvc — a SQL Server service account), and the Client Address (::ffff:192.168.204.129 — Client02, the compromised workstation). The Ticket Options value 0x40810000 is commonly associated with Kerberoasting attempts, as it indicates a forwardable ticket was requested.

```
PS C:\Windows\system32> cd C:\Users\May\Desktop\GhostTrace\Logs-DC
PS C:\Users\May\Desktop\GhostTrace\Logs-DC> Get-WinEvent -Path .\Security.evtx |
>> Where-Object { $_.Id -eq 4769 -and $_.Properties[2].Value -notlike '*$' } |
>> Select-Object TimeCreated,
>>         @{Name='AccountName'; Expression={$_.Properties[0].Value}},
>>         @{Name='ServiceName'; Expression={$_.Properties[2].Value}},
>>         @{Name='SourceIP'; Expression={$_.Properties[6].Value}}
```

TimeCreated	AccountName	ServiceName	SourceIP
5/25/2025 5:25:08 AM	jody@MAIN.LOCAL	krbtgt	::ffff:192.168.204.129
5/25/2025 5:19:50 AM	asmith@MAIN.LOCAL	krbtgt	::ffff:192.168.204.148
5/25/2025 4:42:33 AM	jody@MAIN.LOCAL	sqlsvc	::ffff:192.168.204.129
5/25/2025 3:55:08 AM	DC01\$@MAIN.LOCAL	krbtgt	::ffff:192.168.204.163
5/25/2025 3:40:47 AM	DC01\$@MAIN.LOCAL	krbtgt	::ffff:192.168.204.163
5/25/2025 3:38:49 AM	asmith@MAIN.LOCAL	krbtgt	::ffff:192.168.204.148
5/25/2025 3:37:11 AM	CLIENT02\$@MAIN...	krbtgt	::ffff:192.168.204.129
5/25/2025 3:37:09 AM	CLIENT02\$@MAIN...	krbtgt	::ffff:192.168.204.129

Figure: PowerShell Event ID 4769 filter results showing the sqlsvc Kerberoasting request alongside other TGS requests

✓ Conclusion — Kerberoasting

The attacker used the compromised jody account to execute a Kerberoasting attack via PowerView's Get-DomainSPNTicket cmdlet, requesting a TGS ticket for the sqlsvc service account at 2025-05-25 03:42:33 UTC. The encrypted ticket was subsequently cracked offline to recover the sqlsvc plaintext password.

8. Credential Access — Service Account Password

Following the Kerberoasting attack, the attacker cracked the sqlsvc TGS ticket offline using a tool such as Hashcat or John the Ripper. Offline cracking occurs entirely outside the monitored environment, leaving no detectable trace in any log. The first observable evidence of successful cracking was the attacker's use of the recovered credentials to authenticate to a new system — a clear indicator that the password was now known.

The analyst examined the Security logs of Client03 (192.168.204.148) — a machine the attacker had not yet touched — filtering for Event ID 4624 (Successful Logon) with the username sqlsvc, originating from the attacker's IP address (192.168.204.152). The first successful sqlsvc logon to Client03 from attacker infrastructure was timestamped 2025-05-25 04:03:47 UTC, establishing the earliest point at which the cracked credential was operationally used.

```
PS C:\Users\May\Desktop\GhostTrace\Logs-Client03> Get-WinEvent -Path .\Security.evtx |
>> Where-Object { $_.Id -eq 4624 -and $_.Properties[5].Value -eq 'sqlsvc' } |
>> Select-Object TimeCreated,
>>     @{Name='UserName'; Expression={$_.Properties[5].Value}},
>>     @{Name='SourceIP'; Expression={$_.Properties[18].Value}},
>>     @{Name='LogonType'; Expression={$_.Properties[8].Value}}
```

TimeCreated	UserName	SourceIP	LogonType
5/25/2025 5:17:06 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:17:06 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:17:06 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:17:05 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:16:39 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:16:39 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:16:39 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:16:39 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:05:12 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:05:12 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:05:12 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:05:12 AM	sqlsvc	192.168.204.152	3
5/25/2025 5:03:47 AM	sqlsvc	192.168.204.152	3

Figure: Security Event ID 4624 on Client03 showing sqlsvc first authentication from 192.168.204.152 at 04:03:47 UTC

✓ Conclusion — Credential Access

The sqlsvc service account password was successfully cracked from the Kerberos ticket captured during the Kerberoasting attack. First use of the cracked credential was observed at 2025-05-25 04:03:47 UTC against Client03.

9. Lateral Movement

Attacker Objective

With valid sqlsvc credentials, the attacker sought to move laterally to Client03 — either because it hosted higher-value data or because its logged-in user (lucas) held elevated domain privileges that would enable the next phase of the attack.

PsExec-Based Lateral Movement

The attacker used PsExec — a Sysinternals utility that enables remote command execution on Windows systems using valid credentials. PsExec operates by: authenticating to the target, copying a binary to C:\Windows\, creating a temporary service with a randomly generated name, executing the service (spawning cmd.exe), and then deleting the service. Despite cleanup, forensic artifacts persist in the event logs.

The analyst filtered Sysmon Event ID 1 on Client03 for processes created shortly after the first sqlsvc logon (04:03:47 UTC), looking for services with unusual, randomized names — a hallmark of PsExec. The first service identified was VgYTbFEK.exe, which spawned C:\Windows\SysWOW64\cmd.exe running as NT AUTHORITY\SYSTEM.

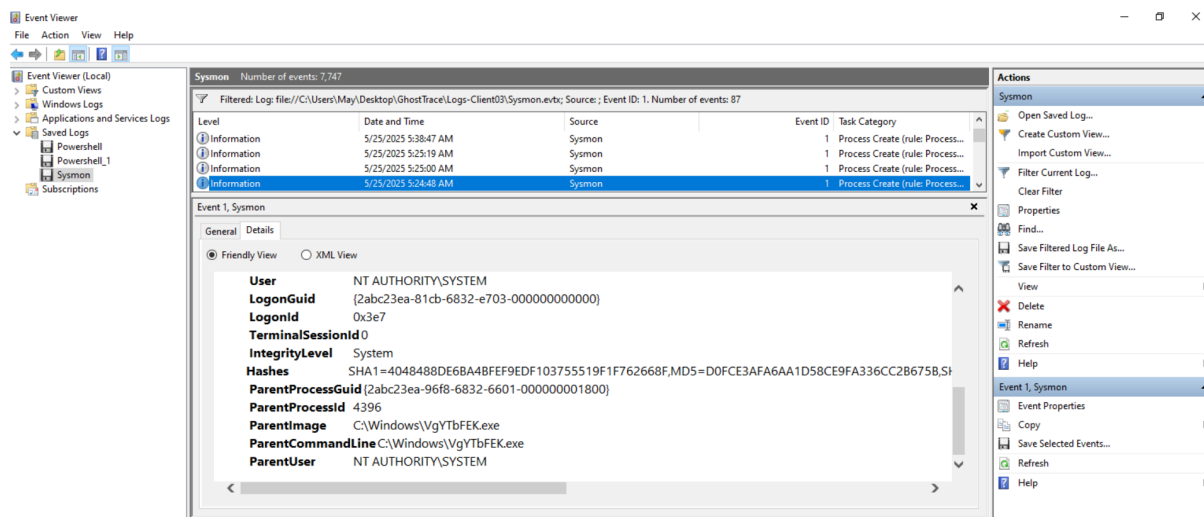


Figure: Sysmon Event ID 1 on Client03 showing VgYTbFEK.exe (PsExec service binary) spawning cmd.exe as SYSTEM

The ParentImage field shows C:\Windows\VgYTbFEK.exe — a randomly named binary dropped by PsExec in C:\Windows\ — and the ParentUser shows NT AUTHORITY\SYSTEM, confirming SYSTEM-level execution. This is the definitive forensic signature of PsExec lateral movement.

✓ Conclusion — Lateral Movement

The attacker used PsExec with cracked sqlsvc credentials to move laterally from their C2 infrastructure to Client03, gaining SYSTEM-level command execution. The PsExec service binary VgYTbFEK.exe was dropped to C:\Windows\ and used to spawn cmd.exe as NT AUTHORITY\SYSTEM.

10. Credential Dumping Analysis

Attacker Objective

Having achieved SYSTEM-level access on Client03, the attacker's next goal was to extract credentials cached in memory — specifically cleartext passwords or NTLM hashes stored in the Windows Local Security Authority Subsystem Service (LSASS) process. These credentials could then be used for further lateral movement or privilege escalation.

Mimikatz Masquerading

Mimikatz is the most widely used credential dumping tool in the threat actor toolkit. Because Mimikatz is heavily signed by endpoint security tools, sophisticated attackers routinely rename it to mimic legitimate system utilities. The analyst reviewed Sysmon Event ID 1 on Client03, focusing on process metadata — specifically the OriginalFileName field, which records the internal file name embedded in the PE header and cannot be altered without recompiling.

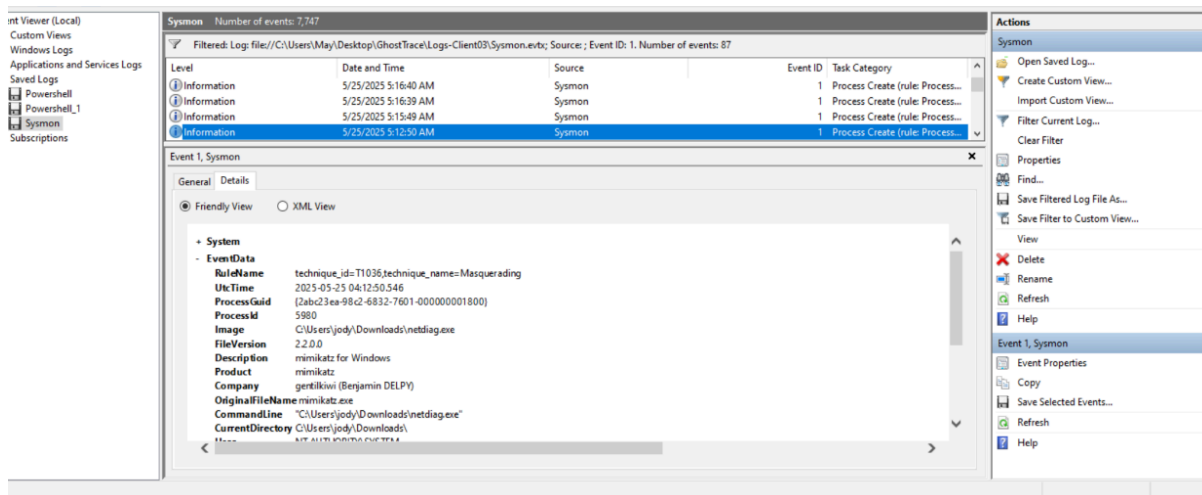


Figure: Sysmon Event ID 1 on Client03 showing netdiag.exe with OriginalFileName=mimikatz.exe — Masquerading technique (T1036) detected

The forensic evidence is unambiguous: an executable named netdiag.exe (a name chosen to impersonate the legitimate Windows Network Diagnostics tool) had an OriginalFileName of mimikatz.exe, a Description of 'mimikatz for Windows', a Product name of 'mimikatz', and a Company of 'gentilkiwi (Benjamin DELPY)' — the Mimikatz author. The Sysmon rule detection also tagged this event with technique_id=T1036, technique_name=Masquerading, confirming automated detection of the renamed executable.

Analyst Note — LSASS Credential Caching

Windows caches credentials in LSASS to enable Single Sign-On. Mimikatz's sekurlsa:logonpasswords command extracts plaintext passwords, NTLM hashes, and Kerberos tickets from LSASS memory. On systems with WDigest authentication enabled (or certain legacy

configurations), plaintext passwords are stored. The subsequent use of the lucas account's credentials confirms that WDigest or an equivalent mechanism was active on Client03.

Following the credential dump, the analyst traced which account credentials were recovered by examining subsequent authentication events. Event ID 4624 on Client03, filtered for logons from attacker infrastructure after the Mimikatz execution time (04:12:50 UTC), revealed the lucas account authenticating from 192.168.204.152.

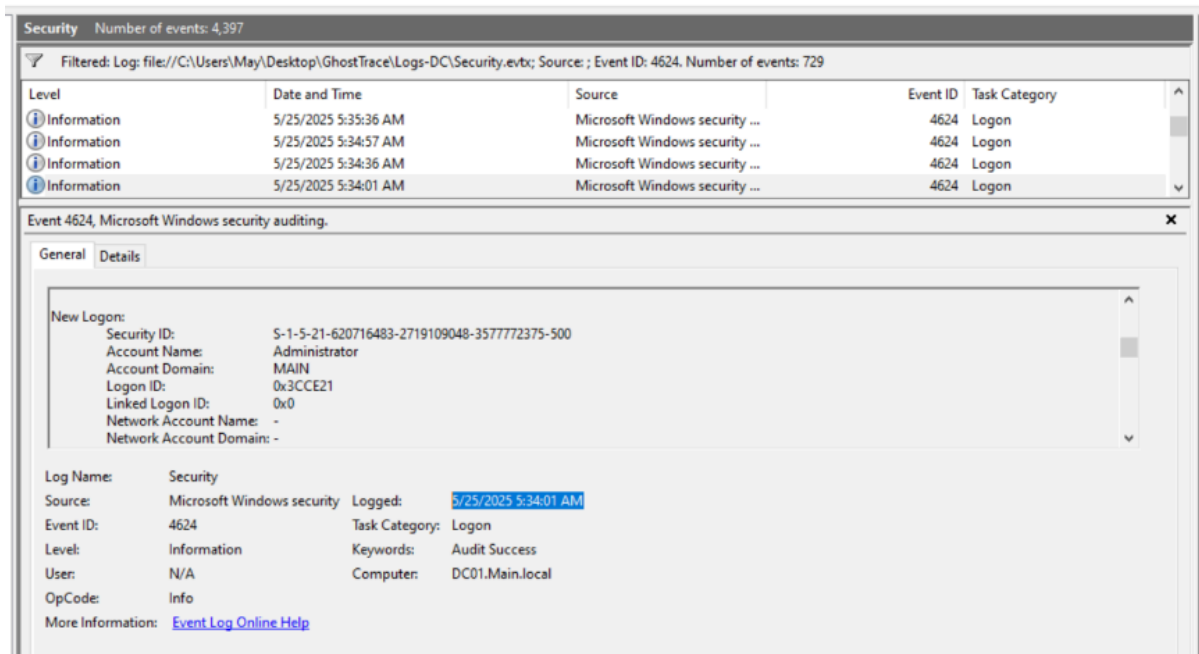


Figure: Security Event ID 4624 on Client03 showing lucas account logon from attacker IP 192.168.204.152 after credential dump

✓ Conclusion — Credential Dumping

The attacker executed Mimikatz (renamed to netdiag.exe) on Client03, extracting the cleartext password of the domain account MAIN\lucas. This account was subsequently used by the attacker, confirming successful credential extraction.

11. DCSync Attack Analysis

Attacker Objective

The discovery of the lucas account credentials represented a critical escalation point. A DCSync attack is an advanced technique where an attacker with the DS-Replication-Get-Changes-All permission impersonates a legitimate Domain Controller and requests password data replication from a real DC — extracting NTLM hashes for every domain account, including the krbtgt and Administrator accounts. This effectively achieves domain compromise without ever touching the DC directly.

Why lucas Was the Key Account

Not every domain account can perform DCSync — the attack requires specific Active Directory permissions. The analyst's hypothesis was that the lucas account had been granted DC Replication permissions, either legitimately (e.g., as a backup service account) or maliciously. This was verified by examining Event ID 4662 (Directory Service Object Access) on the Domain Controller, which records operations performed against AD objects.

DCSync attacks produce a distinctive Event ID 4662 pattern: multiple rapid-fire records showing the target account accessing the domain object (DC=Main,DC=local) with two specific GUIDs in the Properties field:

- 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2 → DS-Replication-Get-Changes
- 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 → DS-Replication-Get-Changes-All (the critical permission enabling hash extraction)

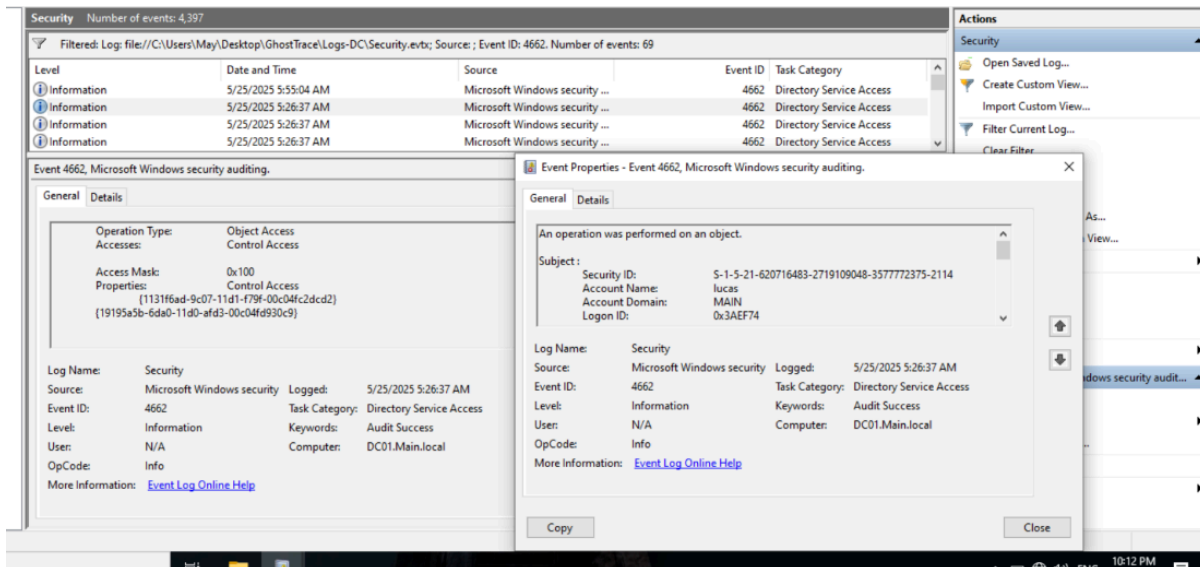


Figure: Security Event ID 4662 on DC01 showing MAIN\lucas accessing DC=Main,DC=local with DS-Replication-Get-Changes-All GUID

The Event ID 4662 records confirmed that MAIN\lucas accessed the domain object with both replication GUIDs. The timestamp was 2025-05-25 04:26:36 UTC. The cluster of four near-simultaneous 4662 events is a characteristic signature of Impacket's secretsdump tool — which makes rapid sequential replication requests when executing DCSync.

 Conclusion — DCSync Attack

The attacker leveraged MAIN\lucas account credentials to execute a DCSync attack against DC01 at 2025-05-25 04:26:36 UTC. The attack extracted NTLM hashes for all domain accounts, including the Administrator account. The four clustered Event ID 4662 records are consistent with Impacket secretsdump DCSync execution.

12. Domain Compromise

Attacker Objective

Having obtained the Administrator NTLM hash via DCSync, the attacker's objective was to leverage this credential for direct access to the Domain Controller — the crown jewel of the Active Directory environment. NTLM hashes can be used without cracking in Pass-the-Hash attacks, or cracked to obtain the plaintext password.

Evidence of Administrator Authentication

The analyst examined DC01's Sysmon logs for Event ID 3 (Network Connection) to identify unusual inbound connections. At 2025-05-25 04:34:01 UTC (UTC+2 system time: 06:34:01), a connection from the attacker's IP (192.168.204.152) to port 5985 was recorded. Port 5985 is the Windows Remote Management (WinRM) / WS-Management HTTP port — indicating an attempt to establish a remote PowerShell session.

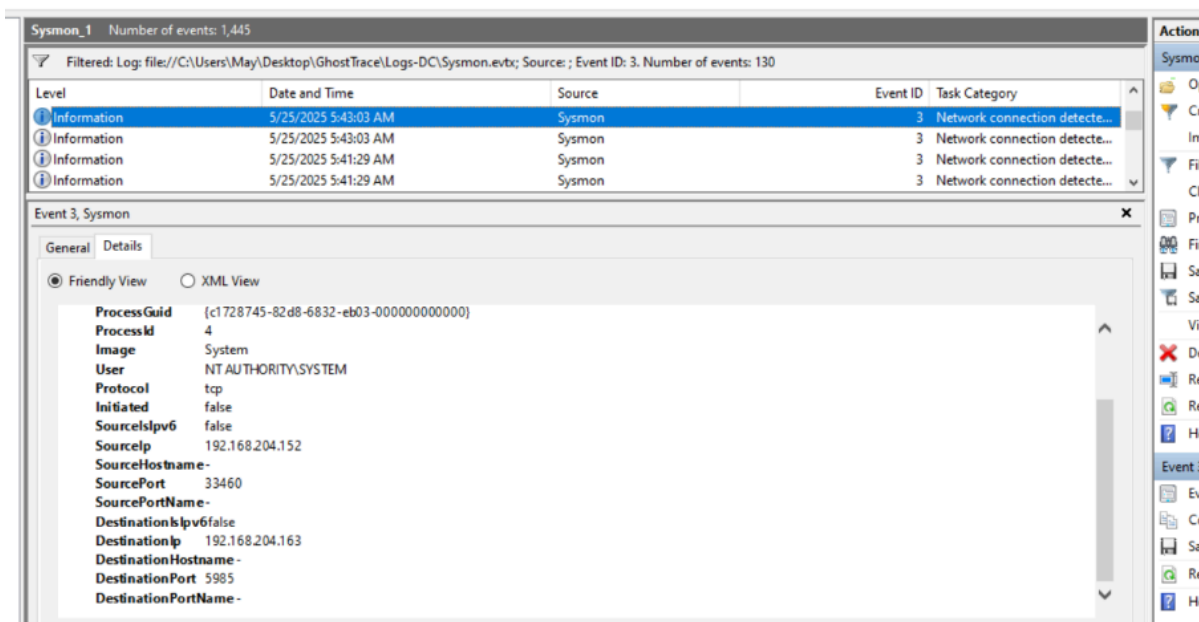


Figure: Sysmon Event ID 3 on DC01 showing inbound connection from 192.168.204.152 to port 5985 at 04:34:01 UTC

Correlating this network event with Sysmon Event ID 1 (Process Create) at the same timestamp revealed the creation of C:\Windows\System32\wsmprovhost.exe — the Windows Remote Management Provider Host, which is spawned precisely when a WinRM session is established. The process's User field showed MAIN\Administrator, confirming that the attacker had authenticated using the Administrator account.

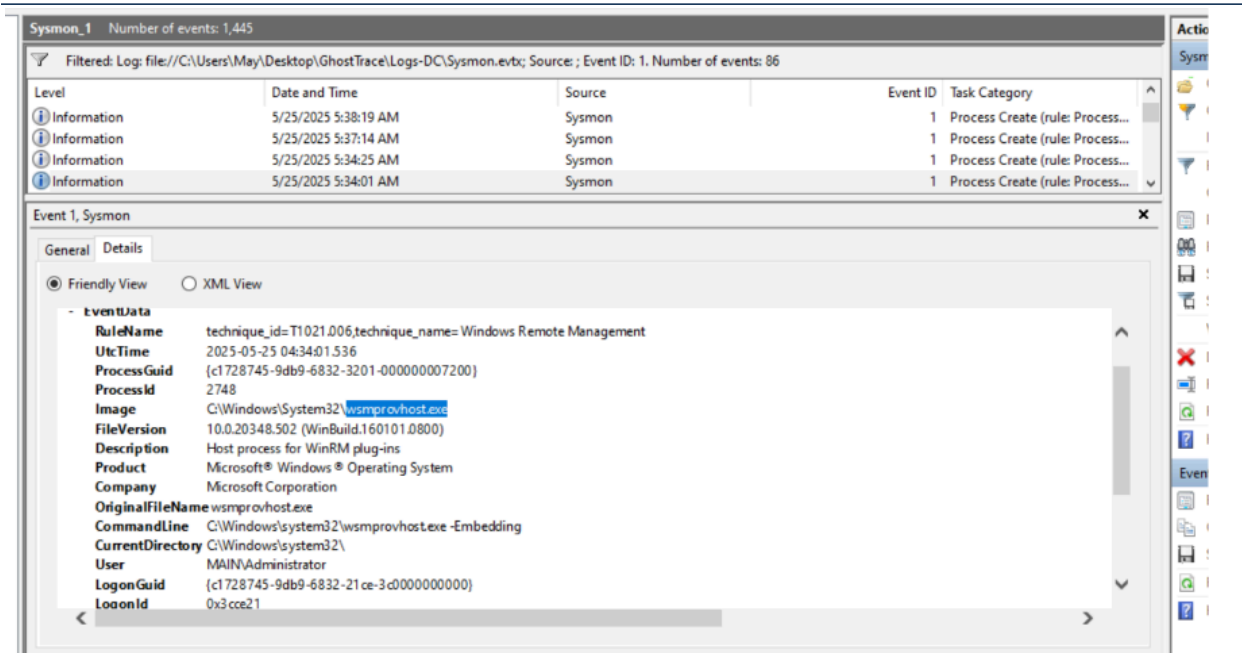


Figure: Sysmon Event ID 1 showing wsmprovhost.exe created at 04:34:01 UTC as MAIN\Administrator — WinRM session confirmed

The Security Event ID 4624 log on DC01 provided the final corroboration: a Logon Type 3 (Network Logon) for MAIN\Administrator at exactly 04:34:01 UTC, originating from the attacker's workstation. This constitutes full domain compromise.

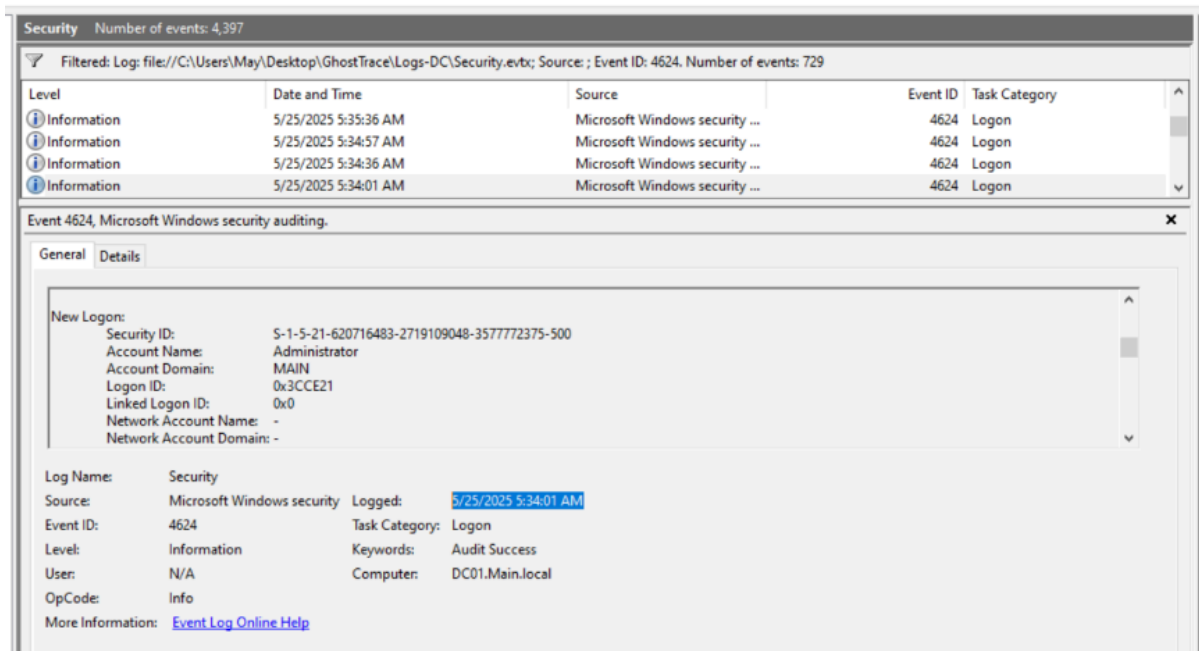


Figure: Security Event ID 4624 on DC01 confirming MAIN\Administrator network logon at 04:34:01 UTC from attacker infrastructure

✓ Conclusion — Domain Compromise

The attacker cracked or pass-the-hashed the Administrator NTLM credential obtained via DCSync, establishing a WinRM session to DC01 at 2025-05-25 04:34:01 UTC as MAIN\Administrator. At this point, the attacker had unrestricted Domain Administrator access — complete domain compromise was achieved.

13. Persistence Mechanisms

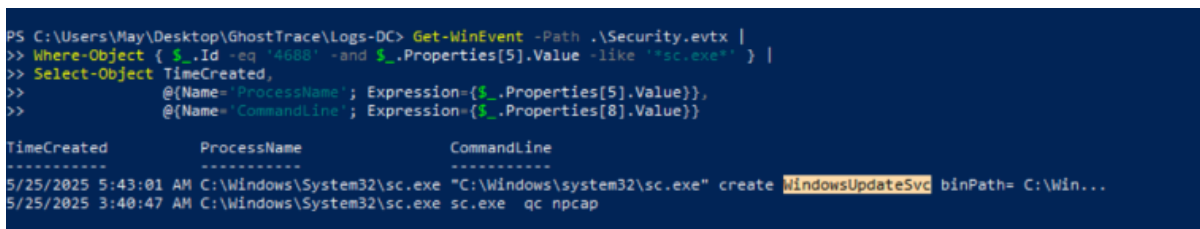
Following domain compromise, the attacker established multiple redundant persistence mechanisms on DC01 — ensuring they could re-enter the environment even if their active session was terminated or the Administrator password was changed.

Persistence Method 1 — Malicious Windows Service

The analyst filtered Security Event ID 4688 (Process Creation) on DC01 for instances of `sc.exe` — the Windows Service Control Manager command-line utility used to create, modify, and delete services. This revealed a command that created a service named `WindowsUpdateSvc`, pointing to `C:\Windows\System32\scvhost.exe` (note: 'scvhost' — a deliberate typosquat of the legitimate 'svchost').

```
sc.exe create WindowsUpdateSvc binPath= C:\Windows\System32\scvhost.exe start=auto
```

The service was configured with `start= auto`, meaning it would automatically launch every time the Domain Controller boots — providing persistent SYSTEM-level code execution that survives reboots and password changes.



```
PS C:\Users\May\Desktop\GhostTrace\Logs-DC> Get-WinEvent -Path .\Security.evtx |
>> Where-Object { $_.Id -eq '4688' -and $_.Properties[5].Value -like '*sc.exe*' } |
>> Select-Object TimeCreated,
>>      @(Name='ProcessName' ; Expression={$_.Properties[5].Value}),
>>      @(Name='CommandLine' ; Expression={$_.Properties[8].Value})
TimeCreated      ProcessName      CommandLine
-----
5/25/2025 5:43:01 AM C:\Windows\System32\sc.exe "C:\Windows\system32\sc.exe" create WindowsUpdateSvc binPath= C:\Win...
5/25/2025 3:40:47 AM C:\Windows\System32\sc.exe sc.exe qc nmap
```

Figure: Security Event ID 4688 on DC01 showing `sc.exe` creating the malicious `WindowsUpdateSvc` service with `scvhost.exe` binary

Persistence Method 2 — Scheduled Task

The analyst examined Security Event ID 4698 (Scheduled Task Created) on DC01. Three scheduled task creation events were found. The relevant task was named `WindowsUpdateCheck` — a name designed to appear as a legitimate Windows maintenance task. The task was configured with a `BootTrigger` (executes on every system boot) and ran `C:\Windows\System32\scvhost.exe` — the same malicious binary used in the service.

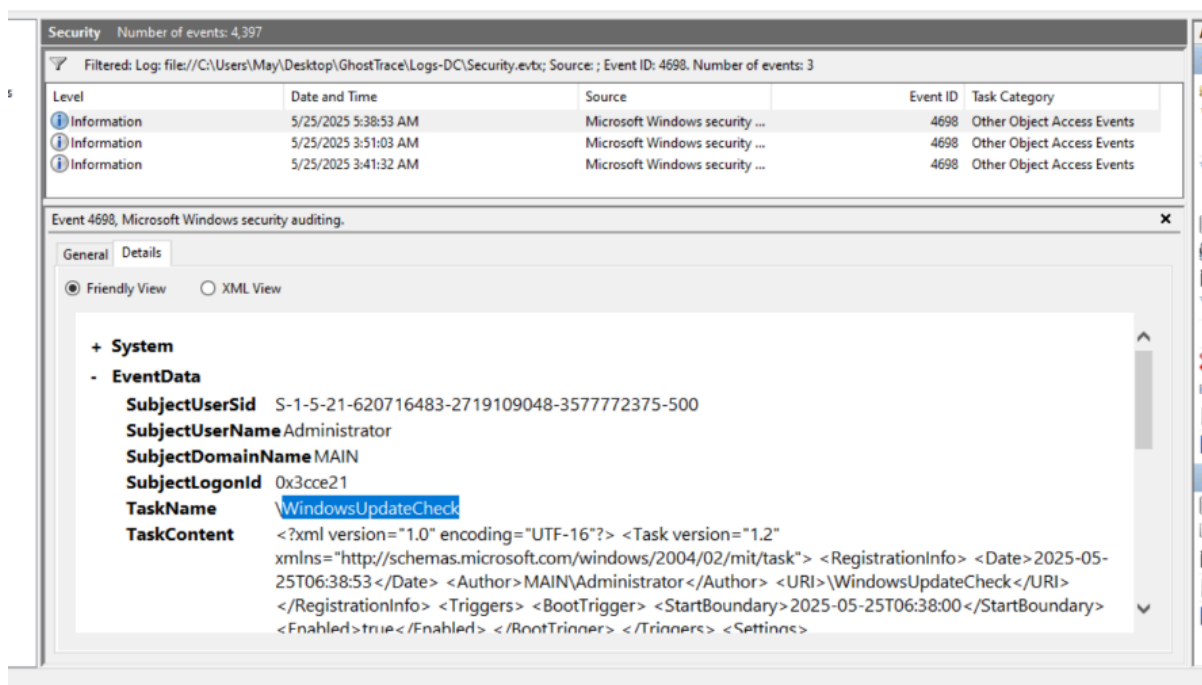


Figure: Security Event ID 4698 on DC01 showing WindowsUpdateCheck scheduled task created by MAIN\Administrator with BootTrigger and scvhost.exe command

Persistence Method 3 — Registry Run Key

The analyst examined Sysmon Event ID 13 (Registry Value Set) on DC01, filtering for values referencing scvhost.exe. This revealed a registry entry added to the HKCU\Software\Microsoft\Windows\CurrentVersion\Run hive under the value name xcvaFctr — an obfuscated, random-looking key name designed to avoid casual inspection. The value pointed to C:\Windows\System32\scvhost.exe.

The analyst confirmed this by also examining Security Event ID 4688 for reg.exe executions, which showed the explicit command used to add the registry key:

```
reg.exe add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v xcvaFctr /t REG_SZ /d C:\Windows\System32\scvhost.exe /f
```

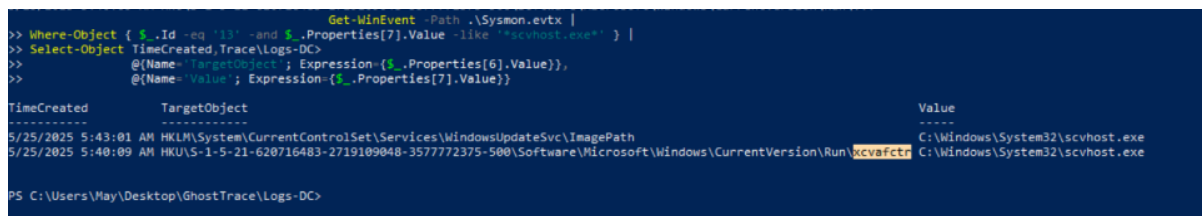


Figure: Sysmon Event ID 13 on DC01 showing xcvaFctr registry Run key set to scvhost.exe — persistence via HKCU Run key

● Persistence Summary

Three independent persistence mechanisms were deployed on DC01, all using the same malicious binary (scvhost.exe) masquerading as a system file:

- Service: WindowsUpdateSvc (auto-start, SYSTEM privileges)
- Scheduled Task: WindowsUpdateCheck (BootTrigger)
- Registry Run Key: xcvafr (HKCU\...\CurrentVersion\Run)

This triple-layer redundancy ensures the attacker maintains access even if defenders discover and remove one mechanism.

14. Detection Opportunities

While this investigation was conducted retrospectively, multiple detection opportunities existed throughout the attack chain. The following table maps each attack phase to the detection mechanism that was (or could have been) triggered:

Attack Phase	Detection Opportunity	Recommended Action
Phishing / File Download	Sysmon Event ID 15 — Zone.Identifier creation for .docm files in Downloads folder	Alert on .docm/.xlsm downloads; disable macros via Group Policy
Macro Execution / C2	Sysmon Event ID 3 — WINWORD.EXE network connections to non-Microsoft IPs	Block Office applications from making outbound network connections
Second-Stage Payload	Sysmon Event ID 3 — Unknown executables connecting to external IPs on non-standard ports	Application whitelisting; block user-writable directory execution
AD Enumeration	PowerShell Event ID 4103 — PowerView cmdlets in pipeline logs	Enable Script Block Logging; alert on known offensive tool signatures
Kerberoasting	Security Event ID 4769 — Multiple TGS requests for service accounts with RC4 encryption	Alert on 0x40810000 ticket options; enforce AES-only service account encryption
Lateral Movement (PsExec)	Security Event ID 7045 — New service installation; Sysmon ID 1 — Random-named executables in C:\Windows\	Alert on new services with random names; restrict lateral movement via firewall rules
Credential Dumping	Sysmon Event ID 1 — OriginalFileName=mimikatz.exe; LSASS access events	Enable Credential Guard; alert on LSASS memory access by non-system processes
DCSync	Security Event ID 4662 — Replication GUIDs 1131f6aa/1131f6ad from non-DC accounts	Alert immediately; only DC computer accounts should trigger these GUIDs
WinRM Access to DC	Sysmon Event ID 3 — Inbound port 5985 connections from non-admin workstations	Restrict WinRM access to jump servers; alert on DC WinRM from user workstations
Registry Persistence	Sysmon Event ID 13 — Run key modifications on Domain Controllers	Alert on any Run key changes on servers; baseline and monitor regularly

15. MITRE ATT&CK® Mapping

The following table maps each phase of the attack to the corresponding MITRE ATT&CK techniques and sub-techniques:

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1566.001	Phishing: Spearphishing Attachment	Profits.docm downloaded from attacker server
Execution	T1204.002	User Execution: Malicious File	User jody opened Profits.docm enabling macros
Execution	T1059.001	PowerShell	PowerShell used for C2 callbacks and tool staging
Command & Control	T1071.001	Web Protocols	PowerShell HTTP connections to 192.168.204.152:80
Command & Control	T1095	Non-Application Layer Protocol	Meterpreter reverse TCP on port 4444
Discovery	T1069.002	Domain Groups	PowerView.ps1 AD enumeration
Discovery	T1087.002	Domain Account	PowerView user and group enumeration
Credential Access	T1558.003	Kerberoasting	TGS ticket for sqlsvc cracked offline
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	PsExec lateral movement to Client03
Credential Access	T1003.001	LSASS Memory	Mimikatz (netdiag.exe) credential dump
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name	netdiag.exe masquerading as mimikatz; scvhost.exe typosquatting
Credential Access	T1003.006	DCSync	lucas account DCSync against DC01
Lateral Movement	T1021.006	Remote Services: Windows Remote Management	WinRM access to DC01 as Administrator
Persistence	T1543.003	Create/Modify System Process: Windows Service	WindowsUpdateSvc malicious service
Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	WindowsUpdateCheck scheduled task
Persistence	T1547.001	Boot/Logon AutoStart: Registry Run Keys	xcvafctr registry Run key

16. Complete Attack Timeline (UTC)

Timestamp (UTC)	System	Event	Technique
2025-05-25 01:27:50	Client02	Profits.docm downloaded from 192.168.204.152	T1566.001
2025-05-25 01:28:03	Client02	Profits.LNK created — user opened document	T1204.002
2025-05-25 01:29:06	Client02	WINWORD.EXE connects to 192.168.204.152:4444 (Meterpreter)	T1095
2025-05-25 01:32:17	Client02	UpdatePolicy.exe connects to 192.168.204.152:1337 (Stage 2 C2)	T1095
2025-05-25 01:37:07	Client02	PowerShell connects to 192.168.204.152:80 (tool staging)	T1071.001
2025-05-25 01:39:22	Client02	PowerView.ps1 downloaded to C:\Users\jody\Downloads\	T1059.001
2025-05-25 03:42:33	DC01 / Client02	Kerberoasting — jody requests TGS for sqlsvc (Event ID 4769)	T1558.003
2025-05-25 04:03:47	Client03	First sqlsvc logon from 192.168.204.152 (cracked password used)	T1021.002
2025-05-25 04:05:12	Client03	Psexec service VgYTbFEK.exe created — SYSTEM shell	T1021.002
2025-05-25 04:12:50	Client03	netdiag.exe (Mimikatz) executed — credential dump	T1003.001
2025-05-25 04:24:47	Client03	lucas account logon from 192.168.204.152 (dumped credentials)	T1078
2025-05-25 04:26:36	DC01	DCSync attack — lucas replicates domain secrets (Event ID 4662)	T1003.006
2025-05-25 04:34:01	DC01	Administrator WinRM logon to DC01 — domain compromise complete	T1021.006
2025-05-25 04:37:09	DC01	Psexec service deployed on DC01 by attacker	T1021.002
2025-05-25 06:40:09	DC01	xcvafctr Run key created (scvhost.exe persistence)	T1547.001
2025-05-25 06:43:01	DC01	WindowsUpdateSvc service created (scvhost.exe)	T1543.003
2025-05-25 06:38:53	DC01	WindowsUpdateCheck scheduled task created	T1053.005

17. Lessons Learned

Defensive Failures That Enabled This Attack

This intrusion succeeded because of a combination of technical misconfigurations and monitoring gaps. Each of the following failures represented a missed opportunity to detect and stop the attack at an earlier stage:

4. Macros were not disabled by Group Policy. The entire attack chain was initiated by a macro-enabled document. Disabling macros organization-wide via GPO, or enforcing macro signing, would have prevented execution.
5. Service accounts had weak, crackable passwords. The sqlsvc account password was cracked offline from its Kerberos ticket — suggesting it did not meet modern complexity requirements. Service accounts should use long, randomly generated passwords (25+ characters) and preferably be converted to Group Managed Service Accounts (gMSA) with automatic password rotation.
6. WDigest authentication appears to have been enabled on Client03, allowing Mimikatz to extract cleartext passwords. WDigest should be disabled via registry (HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest: UseLogonCredential = 0) and Credential Guard should be deployed.
7. The lucas account had DC Replication permissions without necessity. Replication permissions should be restricted exclusively to Domain Controller computer accounts. Auditing accounts with DS-Replication-Get-Changes-All should be a routine security hygiene task.
8. No alerting existed for the DCSync GUID pattern in Event ID 4662. This is one of the most reliable and highest-fidelity detection opportunities for domain compromise — its absence in monitoring represents a critical gap.
9. WinRM was accessible from arbitrary hosts to the Domain Controller. Administrative access to DCs should be routed exclusively through Privileged Access Workstations (PAWs) or jump servers, with network-level controls enforcing this restriction.

Recommended Immediate Remediation Actions

- Reset ALL domain account passwords, prioritizing krbtgt (twice, 10-hour interval) and Administrator
- Revoke and rotate the sqlsvc service account credential; consider gMSA migration
- Remove all three persistence mechanisms: WindowsUpdateSvc service, WindowsUpdateCheck task, xcvafr registry key
- Delete scvhost.exe and VgYtbfEK.exe from affected systems
- Disable WDigest authentication across all domain endpoints via GPO
- Audit all accounts with DS-Replication-Get-Changes-All permissions; remove all except DC computer accounts
- Implement network segmentation blocking direct workstation-to-DC administrative traffic
- Deploy Credential Guard and Windows Defender Credential Guard on all endpoints

-
- Enable and alert on Sysmon, PowerShell Script Block Logging, and Security log coverage across all systems

18. Conclusion

This investigation demonstrates how a single successful phishing email can cascade into complete Active Directory domain compromise in under four hours. The attacker demonstrated a sophisticated understanding of Windows authentication mechanisms, Active Directory architecture, and detection evasion — moving deliberately through each phase with purpose and discipline.

From a defensive forensics perspective, the attack was thoroughly documented across multiple artifact sources. The correlation between Sysmon, Security Event Logs, PowerShell logs, and \$MFT artifacts provided a complete, coherent picture of the attack chain — from the initial file download to the final persistence mechanisms. No single artifact source would have been sufficient; the investigation's strength derived from cross-source correlation.

For defensive teams, the key lessons are not primarily technical — they are strategic. This attack succeeded because multiple independently-defensible chokepoints all failed simultaneously: macro policies, service account hygiene, WDigest configuration, replication permission auditing, and monitoring coverage. Addressing any one of these would have substantially complicated or prevented the attack's progression. Addressing all of them would have made domain compromise effectively impossible.

Final Analyst Statement

The GhostTrace incident is a case study in how defense-in-depth failures compound. Each individual security gap — an unrestricted macro policy, a weak service account password, a misconfigured authentication protocol, an over-permissioned user account — was independently manageable. Together, they created a highway from a phishing email to domain administrator. The path to resilience is not a single fix but a systematic hardening of every link in the defensive chain.

— End of Report —

Author: Mehenni May Fatma Zohra | Digital Forensics & Incident Response | GhostTrace Investigation